HAFTA 4: Hedefi Tanıma ve Mantık Hataları (Web Recon & IDOR)

Şeymanur Yılmaz

28.02.2026

BÖLÜM A

1. Web Anatomisi: HTTP Protokolü

Tarayıcımız (Chrome/Firefox) bir siteye girdiğinde sunucuya bir istek (Request) gönderir, sunucu da ona bir cevap (Response) döner. Bu cevapların başında 3 haneli HTTP durum kodları olur. Pentester için bu sayılar bir yol işaretidir. Mesela bir pentester 403 sayısını gördüğünde o siteye girme yetkisinin olmadığını anlar. Bu durum, kimlik doğrulamanın başarılı fakat yetkilendirmenin kısıtlı olduğu anlamına gelir. Pentester için bu, erişim kontrol mekanizmasının test edilmesi gereken bir noktadır.

2. Kimlik ve Yetki: "Sen Kimsin?"

Cookie, Session ve Token: Bir siteye giriş yaptığımızı düşünelim. Kullanıcı adımız ve şifremizi girip login yaparız. Peki site bizi sonraki sayfalarda nasıl tanıyor yada her yeni sayfada tekrar mı giriş yapıyoruz? Hayır. Burda devreye Cookie, Session ve Token giriyor. **Cookie**, tarayıcıda saklanan küçük veri parçacıklarıdır. Bir nevi not kağıdıdır. **Session**, Sunucunun hafızasındaki dosyadır. Senin not kağıdındaki ID ile sunucudaki dosyayı eşleştirir. Mantığı şöyledir: sitede login olduğumuz anda sunucu bize bir session ID üretir ve bu ID'yi cookie içine koyar. Her istekde bu ID geri göderilir ve sunucu bu ID'ye bakıp bizi tanır. **Token** ise kimlik bilgilerini içinde taşıyan bir veri yapısıdır. Session'dan farklı olarak genellikle sunucu tarafında saklanmaz. İstemci tarafında taşınır ve her istekte doğrulama amacıyla gönderilir**.**

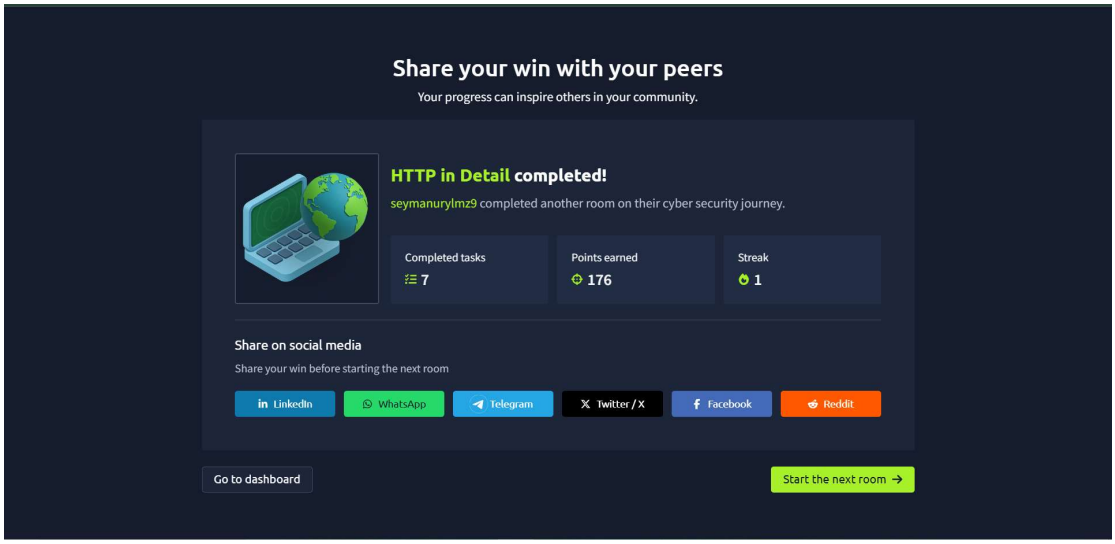
Authentication vs Authorization: Authentication, kullanıcının kimliğinin doğrulanmasıdır. Yani sisteme kullanıcı adı ve şifre ile giriş yapmak authentication işlemidir. Authorization ise kullanıcının sisteme girdikten sonra hangi işlemleri yapabileceğini belirler. Örneğin bir kullanıcının sadece kendi mesajlarını görebilmesi bir yetkilendirme kontrolüdür. Eğer kullanıcı sisteme giriş yapmış olmasına rağmen URL'deki id değerini değiştirerek başkasının mesajlarını okuyabiliyorsa, bu bir authorization (yetkilendirme) zafiyetidir. Bu durum IDOR olarak adlandırılır ve erişim kontrolünün doğru uygulanmadığını gösterir.

3. Zafiyet Mimarisi: IDOR

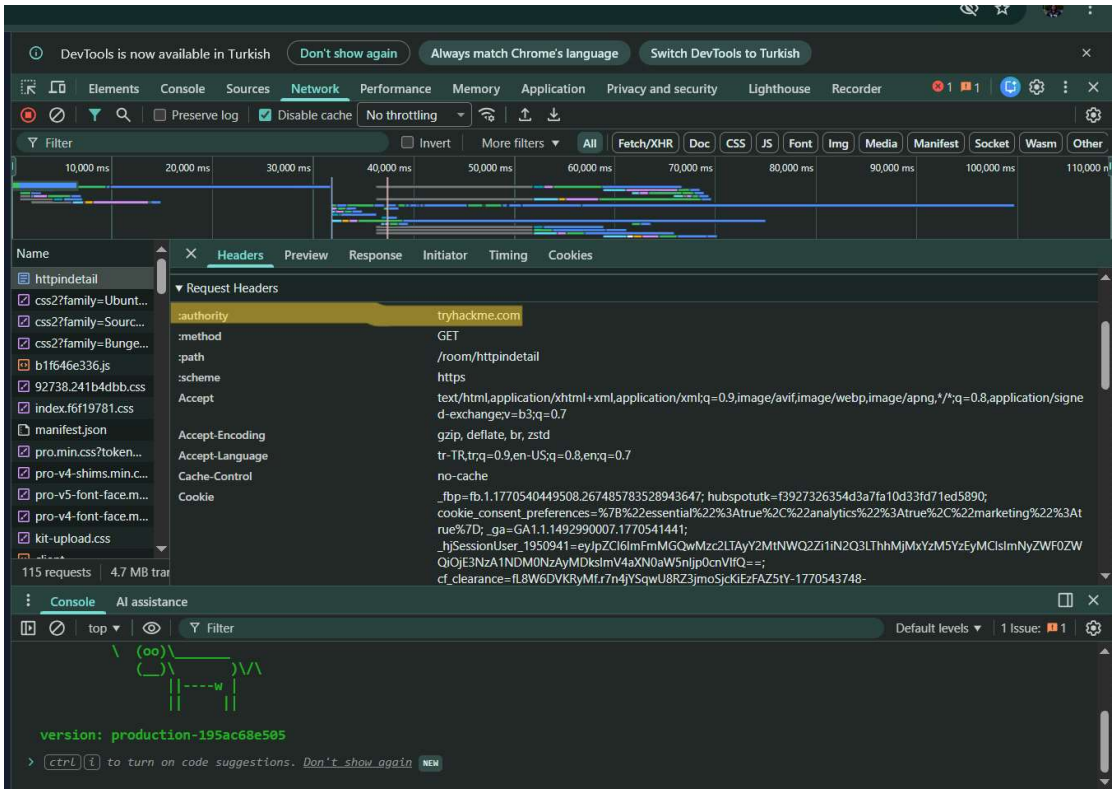
IDOR (Insecure Direct Object Reference): IDOR bir kullanıcının sistemdeki bir nesneye (örneğin kullanıcı bilgisi, mesaj, dosya veya sipariş kaydı gibi) doğrudan bir parametre üzerinden erişebilmesi ve bu parametreyi değiştirerek başkasına ait verilere ulaşabilmesi durumudur. Genellikle URL'de yer alan id gibi değerlerin değiştirilmesiyle ortaya çıkar. Bu zafiyet, yazılımcının backend tarafında gerekli yetkilendirme kontrolünü yapmaması nedeniyle oluşur. Yani sistem kullanıcının kim olduğunu doğrular (authentication yapılır) ancak o kullanıcının ilgili veriye erişim yetkisi olup olmadığını kontrol etmez.

BÖLÜM B

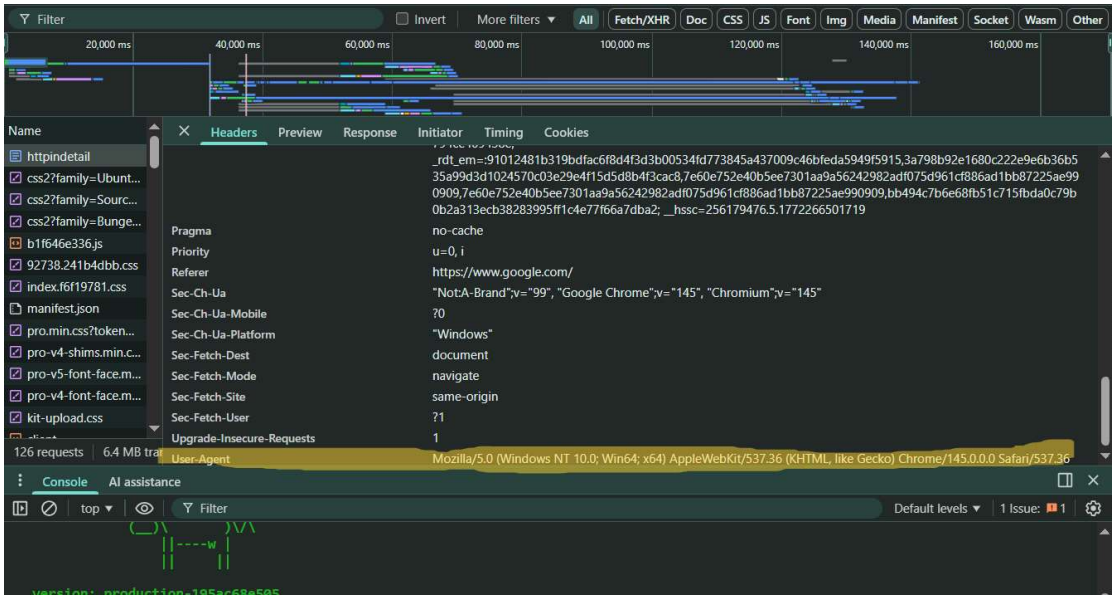
Görev 1: İnternetin Röntgeni (TryHackMe)



Host: Tarayıcının hangi siteye istek göndereceğini sunucuya bildirir.

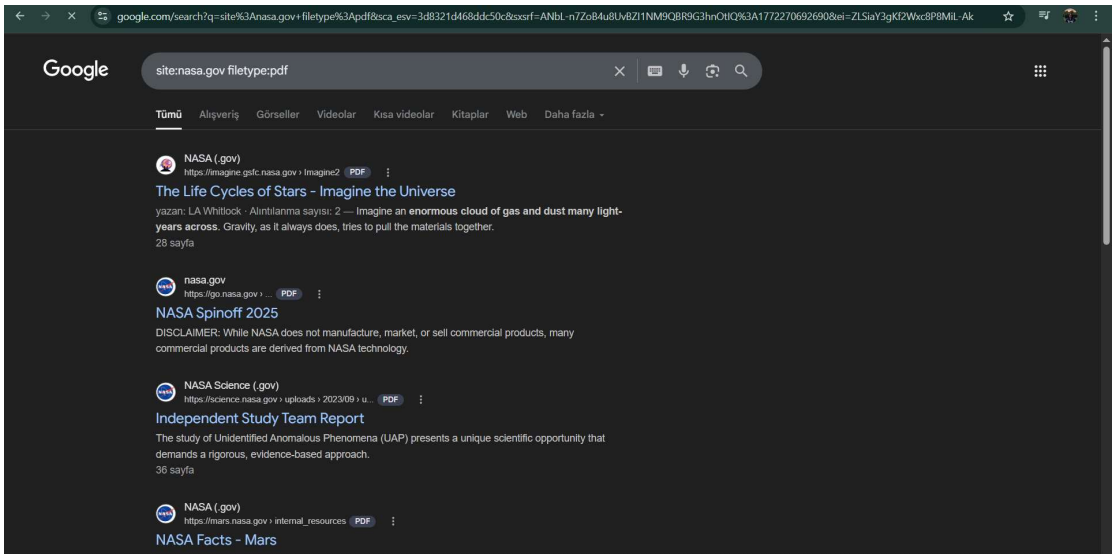


User-Agent: Tarayıcı kendisi hakkında bilgi verir. Hangi tarayıcıyı, hangi sürümü kullandığını söyler. Örneğin Chrome mu, Firefox mu, mobil mi, bilgisayar mı gibi. Sunucu buna bakıp siteyi ona göre gösterebilir.



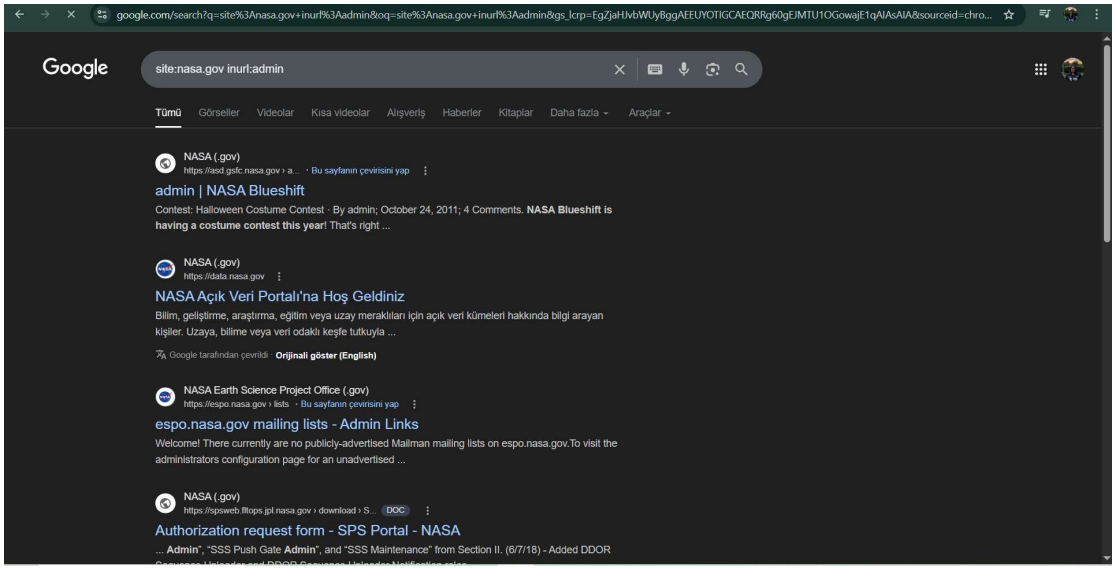
Görev 2: Google Dorking (Açık Kaynak İstihbaratı)

1) site:nasa.gov filetype:pdf



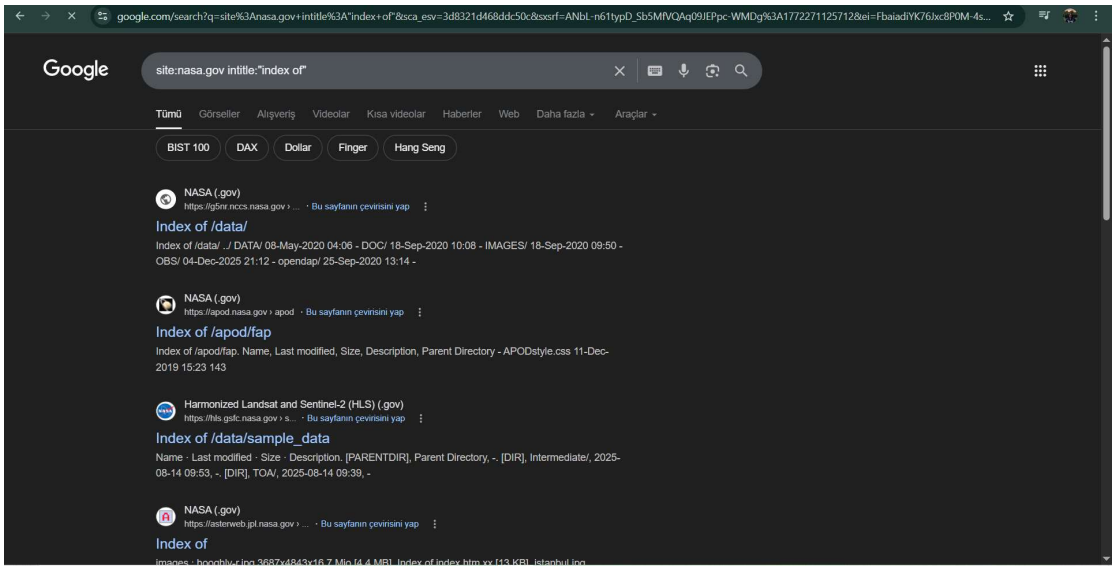
Hedef domain altındaki tüm PDF dosyalarını listeler. Kurumun yanlışlıkla halka açık bıraktığı raporlar, strateji belgeleri veya teknik şemaları bulmak için kullanılır.

2) site:nasa.gov inurl:admin



URL içerisinde admin kelimesi geçen sayfaları getirir. Bu, saldırganların kaba kuvvet (brute-force) denemesi yapabileceği yönetim panellerini bulmasını sağlar.

3) site:nasa.gov intitle:"index of"



unucu üzerinde klasör listeleme özelliği açık olan dizinleri bulur. Bu sayede web sitesinin kaynak kodlarına, yedeklerine veya log dosyalarına doğrudan erişim sağlanabilir.

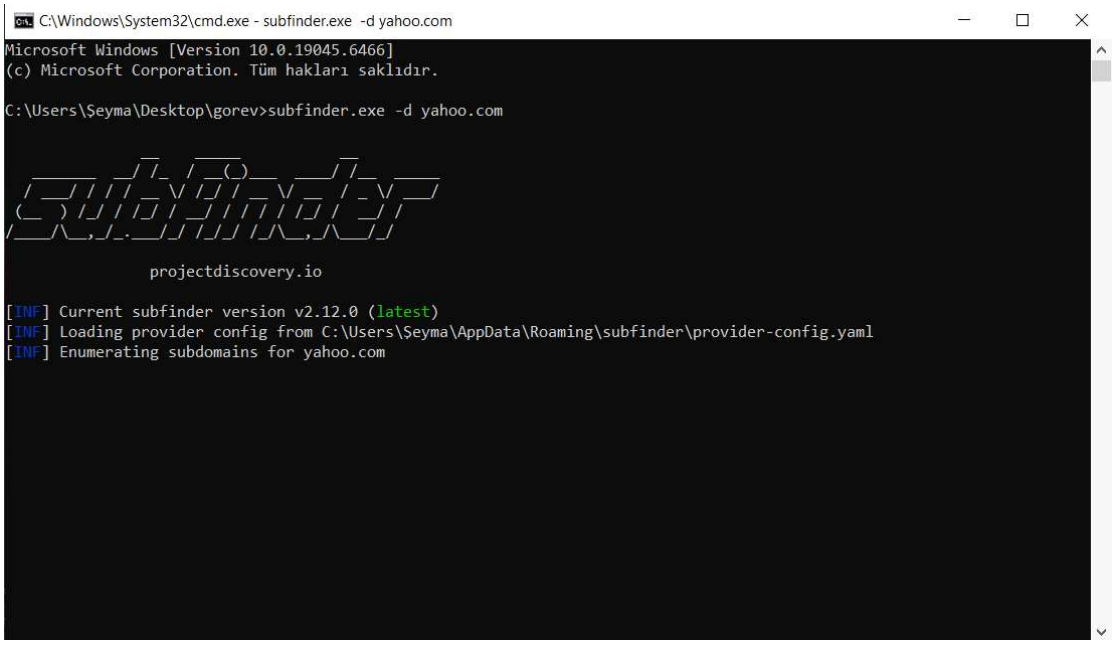
BÖLÜM C

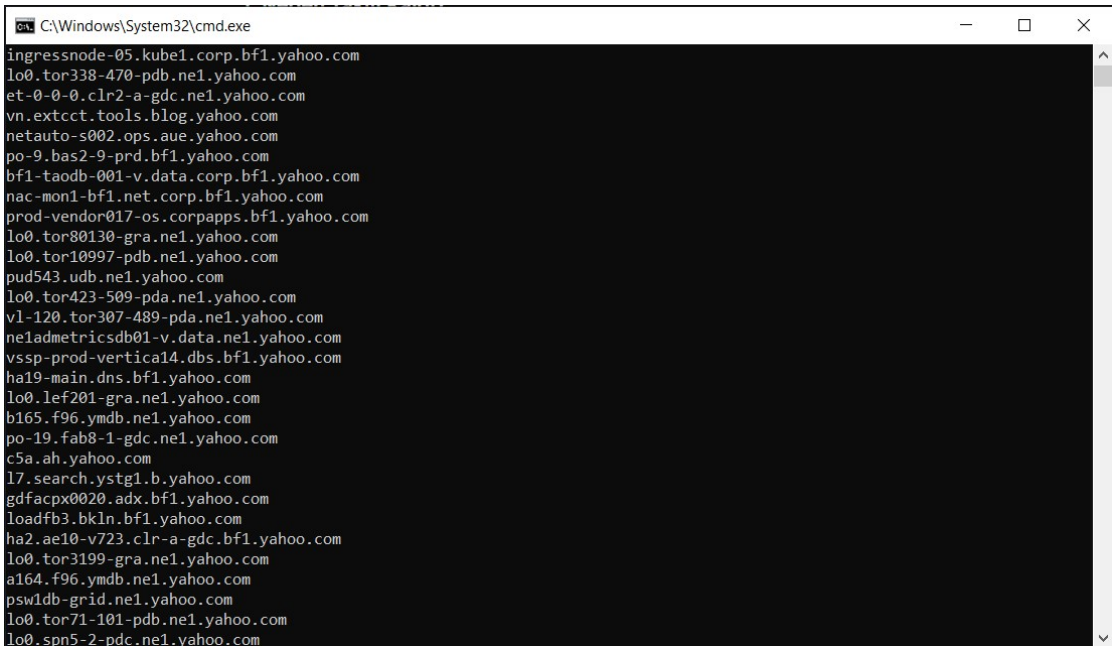
Cephe 1: Hayalet Avı (Recon Haritası)

İlk olarak github üzerinden subfinder ve httpx dosyalarını indirdim. İnen dosyaları bilgisayarımda ayıkladım ve subfinder.exe ile httpx.exe dosyalarını ayrı bir klasöre

kopyalayıp CMD' yi orda çalıştırdım.

Komut sisteminden ilk subfinder.exe -d yahoo.com komutunu çalıştırdım ve tarama sonucunda Yahoo domainine ait toplam 100.000 tane potansiyel alt alan adı tespit ettim.





Bulduğum binlerce ismin gerçekten çalışıp çalışmadığını anlamak için bir "canlılık kontrolü" yapmam gerekiyordu.

İşlemi hızlandırmak ve internetimi verimli kullanmak için subfinder.exe -d yahoo.com -silent | httpx.exe -sc -title -t 100 -rl 50 komutunu kullandım (Burada -t 100 kullanarak aynı anda 100 isteği kontrol edip, -rl 50 ile de internetimi yormamak için saniyede 50 istek sınırı koydum).

```
C:\Windows\System32\cmd.exe
bf1-lnxdownloader-626.adx.bf1.yahoo.com
lo0.lef262-gra.ne1.yahoo.com
lo0.lef251-pdb.ne1.yahoo.com
cc.profiles.yahoo.com
xe-10-3-0.clr1-a-gdc.bf1.yahoo.com
ne1edlitedb-007.data.ne1.yahoo.com
lo0.tor322-459-pdb.ne1.yahoo.com
bf1-inxctworker-023.adx.bf1.yahoo.com
et3.egr1-1-pdc.bf1.yahoo.com
a146.f96.ymdb.ne1.yahoo.com
vl-121.tor65-46-gra.ne1.yahoo.com
sg.style.yahoo.com
oxy-oxygen-42a3b056.ne1.yahoo.com
im3.del.bf1.yahoo.com
[INF] Found 14298 subdomains for yahoo.com in 1 minute 14 seconds

C:\Users\Seyma\Desktop\gorev>subfinder.exe -d yahoo.com -silent | httpx.exe -sc -title

projectdiscovery.io

[INF] Current httpx version v1.8.1 (latest)
[WRN] UI Dashboard is disabled, Use -dashboard option to enable
```

```
C:\Windows\System32\cmd.exe
projectdiscovery.io

[WRN] UI Dashboard is disabled, Use -dashboard option to enable
https://2013-en-imagenes.es.yahoo.com [301] [Yahoo]
http://3p-geo.yahoo.com [301]
http://360.yahoo.com [301] [Yahoo]
https://about.yahoo.com [301] [Yahoo]
http://accountkey.yahoo.com [301] [Document Has Moved]
http://address.yahoo.com [301] [Document Has Moved]
http://add.my.yahoo.com [301] [Yahoo]
http://admanagerplus.yahoo.com [301] [Document Has Moved]
http://admanager.yahoo.com [301] [Yahoo]
http://admin.nevec.yahoo.com [301]
https://advertisingcentral.yahoo.com [301] [Yahoo]
http://adspecs.yahoo.com [301] [Yahoo]
http://advertising.yahoo.com [301]
http://ads.yahoo.com [204]
http://aiuto.yahoo.com [301] [Yahoo]
http://answers.search.yahoo.com [301] [Yahoo]
http://api.reg.yahoo.com [301] [Document Has Moved]
http://asia.yahoo.com [301] [Yahoo]
http://at.yahoo.com [301] [Yahoo]
http://au.biz.yahoo.com [301] [Yahoo]
http://au.alpha.yahoo.com [301] [Yahoo]
http://au.forums.yahoo.com [404] [Yahoo]
```

Çıktılar arasından güvenlik açısından dikkatimi çeken 3 tane subdomain vardı:

1) ads.yahoo.com [204]: Diğerlerinden farklı olarak "204" kodu dönmesi buranın bir takip/analiz servisi olduğunu gösteriyor. Sıradışı bir kod olduğu için incelenmeye değer buldum.

2) accountkey.yahoo.com [301]: Kayıt süreçlerini yöneten bir API ucu olduğu için kullanıcı verisi sızıntısı veya IDOR zafiyetleri için en kritik noktadır.

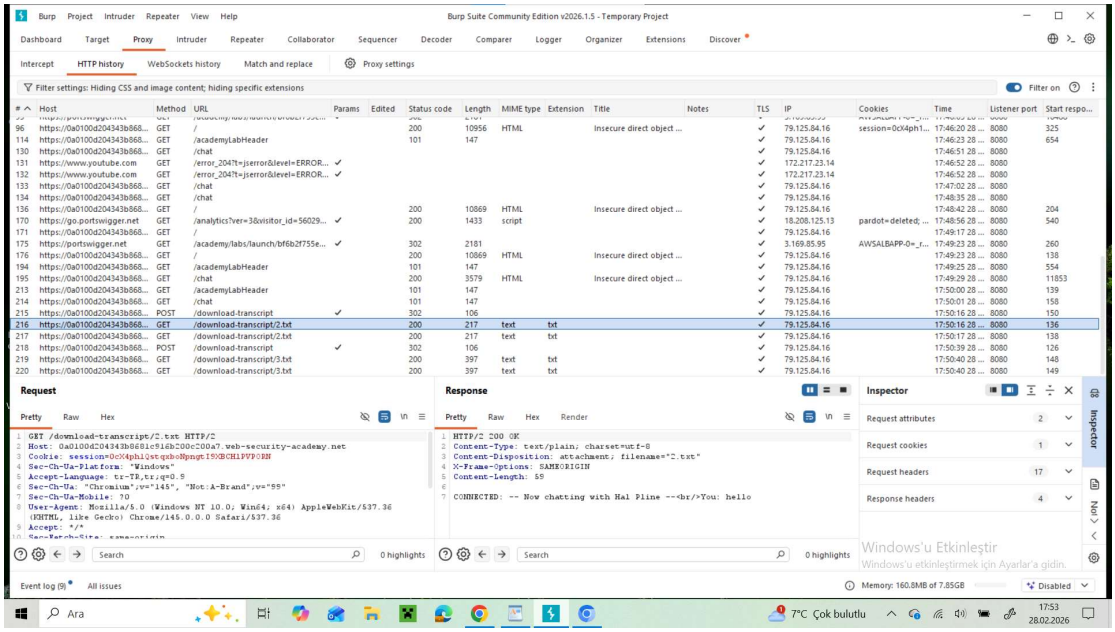
3) au.forums.yahoo.com [404]: Sayfanın bulunamaması bana burada eskiden çalışan bir servisin unutulmuş olabileceğini ve Subdomain Takeover (Alt Alan Adı Ele Geçirme) riski taşıyabileceğini düşündürdü.

Cephe 2: Yetkiyi Delmek (PortSwigger Labs)

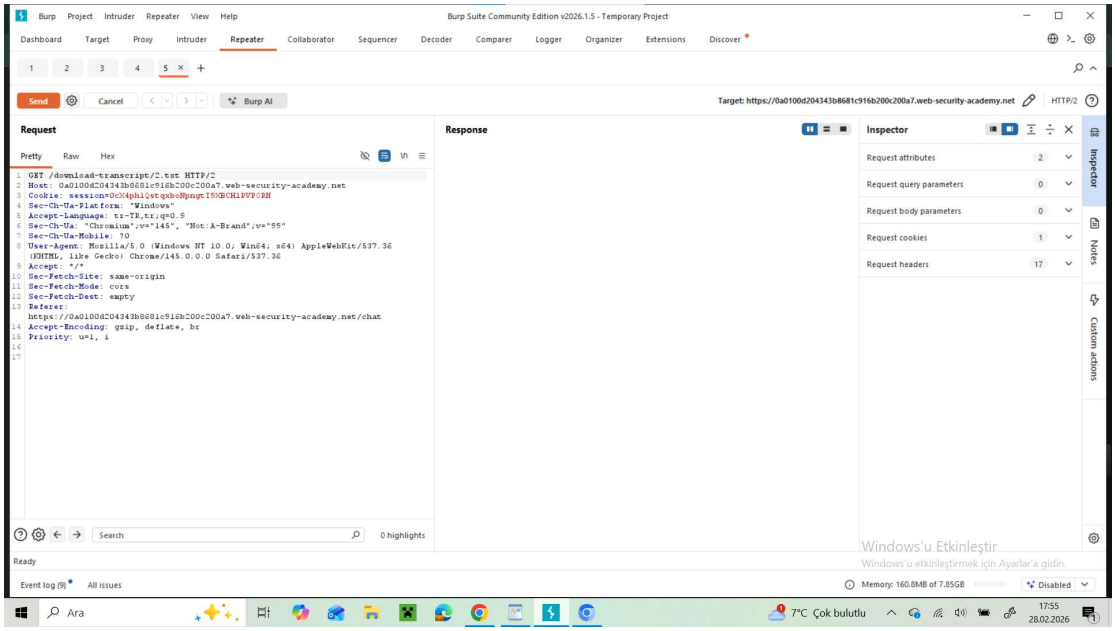
Lab çalışmalarına başlarken ilk başta sadece tarayıcı üzerinden ilerlemeye çalıştım fakat verileri manipüle etmek için Burp Suite kullanmam gerektiğini fark ettim. Programı kurduktan sonra "Stream failed to close correctly" hatasıyla karşılaştım ve tarayıcıyı açamadım. Bu sorunu Burp Suite ayarlarından "Sandbox" özelliğini kapatarak ve programı yönetici olarak çalıştırarak çözdüm.

1. Lab 1: Dosya Erişimi Üzerinden IDOR

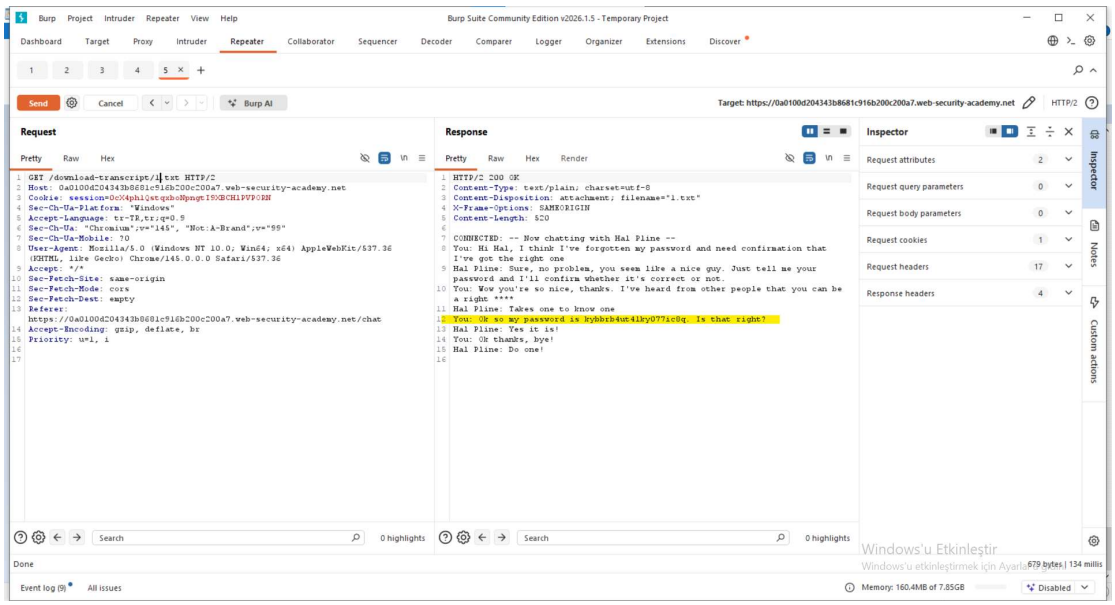
İlk olarak Live Chat kısmına girip "Hello" yazarak bir trafik oluşturdum. "View Transcript" dediğimde sistemin bana 2.txt dosyasını verdiğini gördüm.



Bu isteği Burp Suite Repeater modülüne gönderdim. 2.txt olan dosya adını manuel olarak 1.txt yaparak sunucuya tekrar gönderdim.

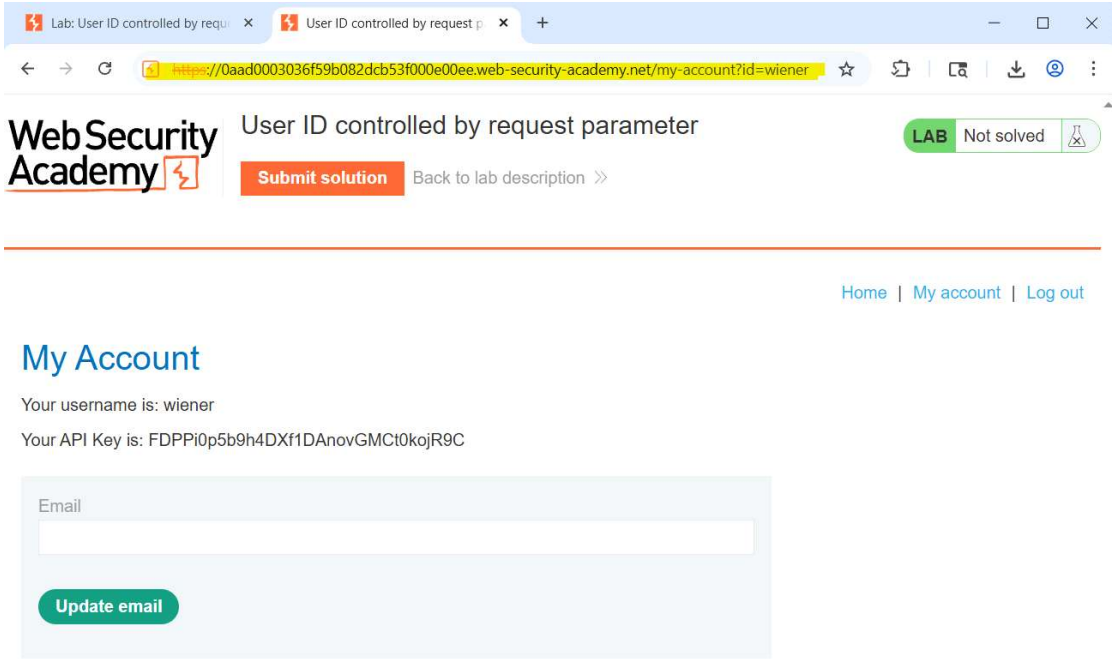


1.txt dosyasının içinde Hal Pline isimli botun bir kullanıcıyla yaptığı konuşmaya ulaştım. Konuşmanın sonunda kullanıcının şifresini (kybbrb4ut4lky077ic8q) açıkça yazdığını gördüm. Bu şifreyle Carlos hesabına giriş yaparak ilk aşamayı tamamladım.

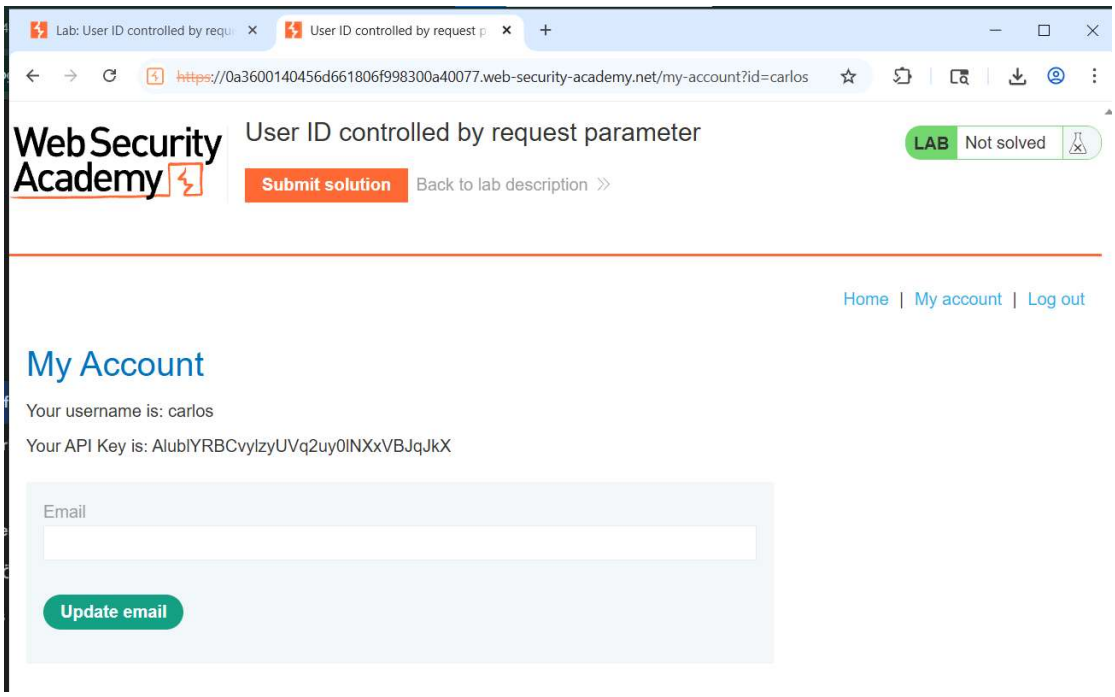


2. Lab 2: URL Parametresi Üzerinden IDOR

Sistemin bana verdiği kullanıcı adı ve şifre ile giriş yaptığımda URL'nin sonunda id=wiener yazdığını fark ettim.



Hiç Burp Suite kullanmaya gerek kalmadan, doğrudan tarayıcı adres çubuğundaki wiener kısmını silip carlos yazdım.



Sayfa yenilendiğinde Carlos'un profil sayfasını ve ona özel API Key bilgisini (AlublYRBCvylzyUVq2uy0INXxVBJqJkX) karşımda buldum. Bu anahtarı çözüm kısmına girerek labı bitirdim.

BÖLÜM D

1. IDOR'un Gerçek Hayat Etkisi (Impact): Bir hastanenin e-randevu veya tahlil sisteminde IDOR yüzünden başka bir hastanın HIV ya da kanser sonuçlarına erişilebilmesi, KVKK açısından en ağır ihlallerden biridir. Çünkü bu veriler özel nitelikli kişisel veri sayılır ve sızması şirkete yüksek para cezası olarak geri döner. Böyle bir olay medyaya yansıdığında hastane güvenilirliğini kaybeder ve hastalar sisteme karşı şüphe duyar. Bu nedenle rapor yazarken risk seviyesini kritik ya da çok yüksek etki olarak açıklardım; çünkü zafiyet hem hukuki hem finansal hem de marka açısından doğrudan ve ağır bir zarar oluşturur.

2. Güvenin Bedeli (Zero Trust): IDOR ve Broken Access Control'ün temel nedeni, yazılımcının kullanıcıdan gelen veriye gereğinden fazla güvenmesidir. Bir mühendis olarak bunu engellemek için backend tarafında her istekte mutlaka yetki doğrulaması yapılması gerekir. Yani sunucu, URL veya parametrede gelen id değerini hiçbir şekilde doğru kabul etmemeli ve her zaman "Bu kullanıcı gerçekten bu kaynağa erişebilir mi?" sorusunu kontrol etmelidir. Kullanıcının rolü, kendi verisi olup olmadığı, kaynak sahibinin kim olduğu gibi bilgiler sunucu tarafında doğrulanmadıkça isteğe izin verilmemelidir. Bu aslında Zero Trust mantığının yazılım tarafındaki en temel uygulamasıdır.